

系統帳號風險分析

By YC





總覽

權限授予不適當

帳號啟用早於到職日

帳號許久未登入

離職帳號未停用

總結

50

系統帳號總數

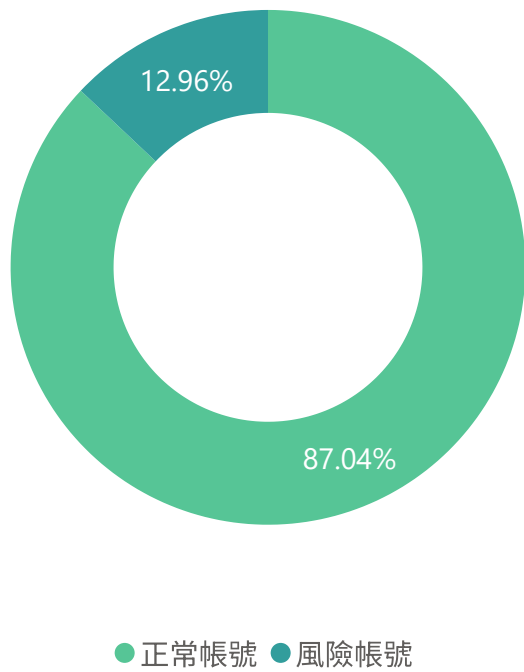
7

風險帳號計數

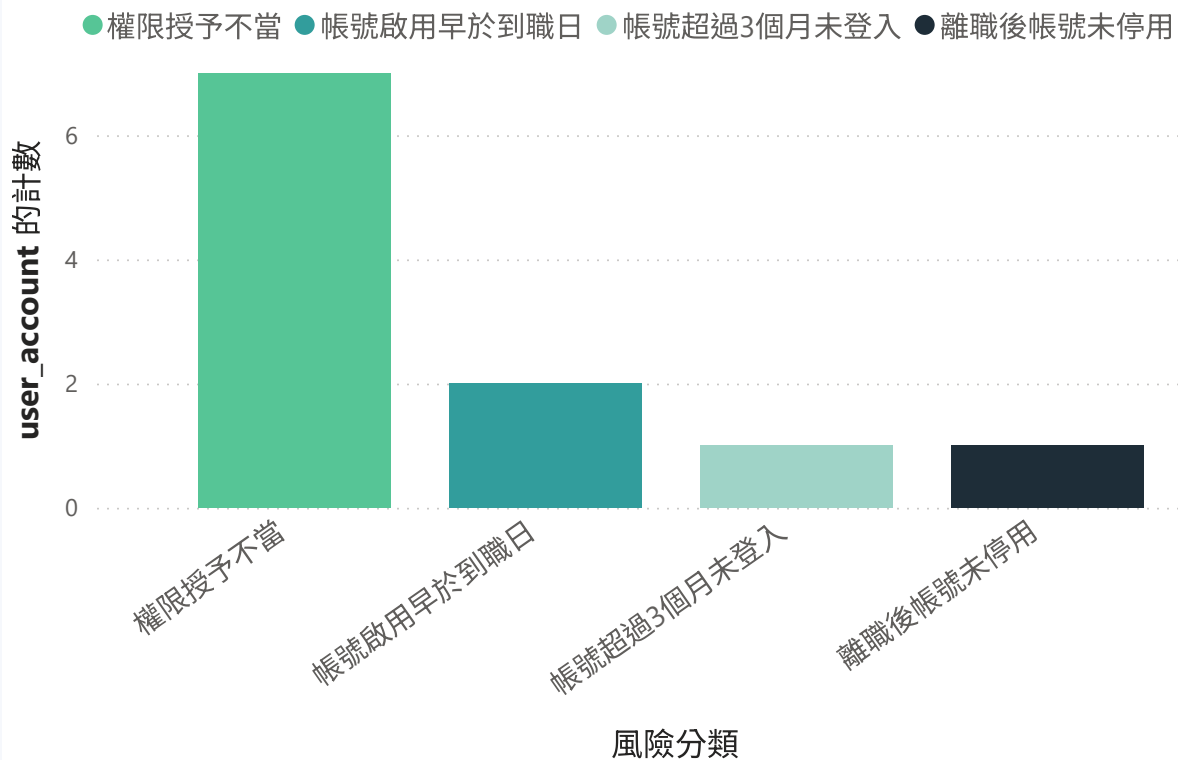
14.00%

風險帳號比率

帳號異常比例



風險帳號分類





總覽

權限授予不適當

帳號啟用早於到職日

帳號許久未登入

離職帳號未停用

總結

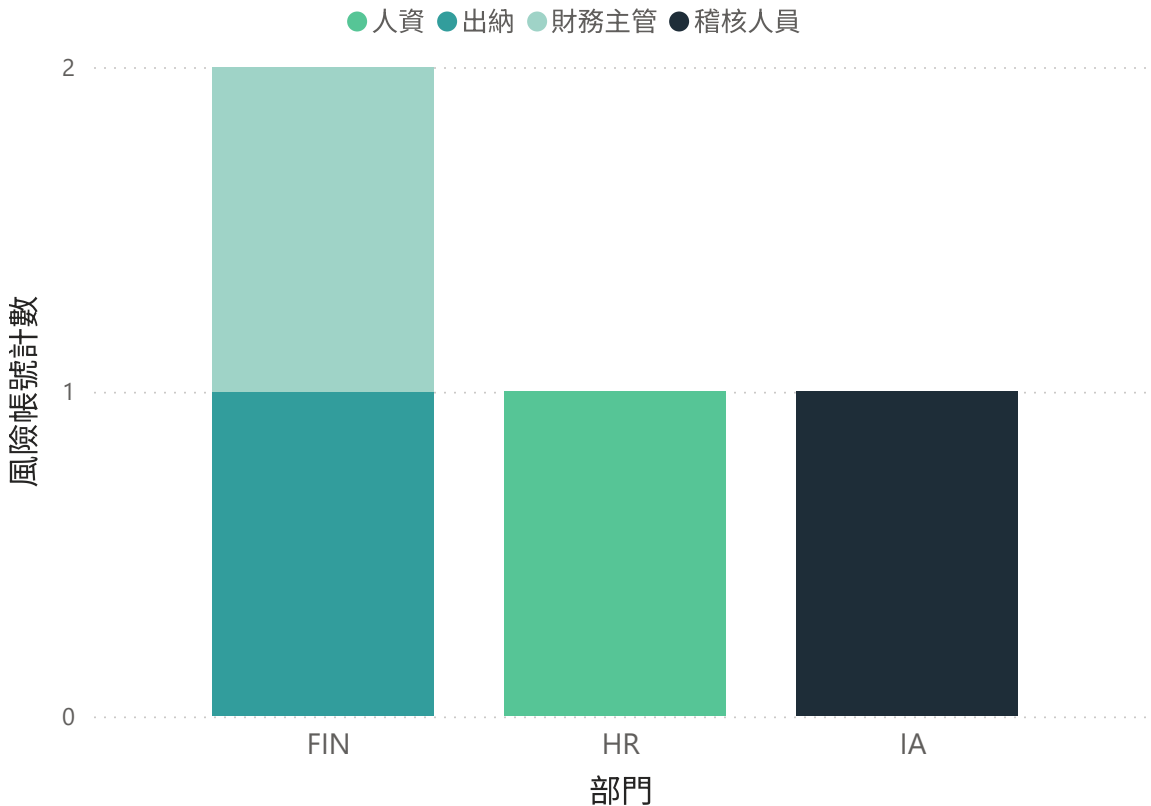
4

風險帳號計數

8%

風險帳號比率

風險帳號分類



風險帳號及對應權限

帳號	部門	職稱	權限	風險分類
ERP0002	IA	稽核人員	查閱	
ERP0002	IA	稽核人員	客戶資料維護	權限授予不當
ERP0002	IA	稽核人員	銷售訂單維護	權限授予不當
ERP0011	FIN	財務主管	傳票核准	
ERP0011	FIN	財務主管	費用報支審核	權限授予不當
ERP0011	FIN	財務主管	編製會計憑證	權限授予不當
ERP0019	FIN	出納	出納確認	

⚠ 風險摘要

- 稽核人員兼有業務權限 → 角色混淆影響公正性
- 財務主管掌握完整流程 → 缺乏制衡
- 出納同時製作憑證與付款 → 單人可獨立決定帳務
- 人資跨部門持有會計權限 → 違反職責分離、降低審核有效性

🔧 改善建議

- 定期審查角色與權限
- 留存稽核操作日誌並審查
- 權限最小化原則

詳細說明

[總覽](#)[權限授予不適當](#)[帳號啟用早於到職日](#)[帳號許久未登入](#)[離職帳號未停用](#)[總結](#)

風險帳號及對應權限

帳號	部門	職稱	權限	風險分類
ERP0002	IA	稽核人員	查閱	
ERP0002	IA	稽核人員	客戶資料維護	權限授予不當
ERP0002	IA	稽核人員	銷售訂單維護	權限授予不當
ERP0011	FIN	財務主管	傳票核准	
ERP0011	FIN	財務主管	費用報支審核	權限授予不當
ERP0011	FIN	財務主管	編製會計憑證	權限授予不當
ERP0019	FIN	出納	出納確認	
ERP0019	FIN	出納	付款	
ERP0019	FIN	出納	編製會計憑證	權限授予不當
ERP0046	HR	人資	員工資料維護	
ERP0046	HR	人資	招聘作業	
ERP0046	HR	人資	費用報支審核	權限授予不當
ERP0046	HR	人資	編製會計憑證	權限授予不當

⚠ 風險說明

- 稽核人員兼有業務權限 → 角色混淆影響公正性
 - 稽核人員職責應專注於查閱，倘若同時擁有其他業務性權限，恐涉角色混淆，影響稽核之客觀性與公正性。
- 財務主管掌握完整流程 → 缺乏制衡
 - 為維持職責分工與內部控制之健全，財務主管不應同時擁有費用報支審核、編製會計憑證及核准傳票之完整流程權限。
- 出納同時製作憑證與付款 → 單人可獨立決定帳務
 - 出納及會計的職責區分不當，若出納除執行付款外，尚參與憑證編製，可能導致出納可自行決定帳務內容並執行付款，失去必要的雙重牽制。
- 人資跨部門持有會計權限 → 違反職責分離、降低審核有效性
 - 人力資源部門若同時擁有「編製會計憑證」與「費用報支審核」權限，將涉及跨部門職能重疊，違反職責分離原則，人資若能自行審核與編製憑證，可能虛構津貼、加班費、假發票等項目，自行入帳核銷，難以被偵測。且人資並非會計專業，難以判斷報支是否符合財務制度與帳務邏輯，降低審核有效性。

🔧 改善建議

- 定期審查角色與權限

[返回摘要](#)



總覽

權限授予不適當

帳號啟用早於到職日

帳號許久未登入

離職帳號未停用

總結

1

風險帳號計數

2%

風險帳號比率

風險帳號分類

PD

1 (100%)



帳號啟用日與到職日相差天數



風險帳號相關欄位之資訊

帳號	部門	職稱	帳號建立日	到職日	風險分類
ERP0026	PD	採購人員	2023/2/23	2023/2/28	帳號啟用早於到職日

⚠ 風險：帳號啟用早於到職日

1. 資訊外洩或不當使用 → 未報到前即能存取敏感資料。
2. 權責不明 → 帳號被濫用時難以追責。
3. 流程漏洞 → 人員異動與帳號管理不嚴謹，易遭利用。

🔧 改善建議

1. HR 與 IT 流程整合
2. 留存稽核操作日誌並審查
3. 強制首次登入改密碼

詳細說明

[總覽](#)[權限授予不適當](#)[帳號啟用早於到職日](#)[帳號許久未登入](#)[離職帳號未停用](#)[總結](#)

風險帳號相關欄位之資訊

帳號	部門	職稱	帳號建立日	到職日	風險分類
ERP0026	PD	採購人員	2023/2/23	2023/2/28	帳號啟用早於到職日

⚠ 風險：帳號啟用早於到職日

1. 資訊外洩或不當使用 → 未報到前即能存取敏感資料。
 - 在員工尚未正式就職、接受培訓與了解公司規範前，其帳號可能被濫用以存取敏感資料，造成資料外洩或不當使用，理想狀況應於員工到職日當日建立並啟用帳號。
2. 權責不明 → 帳號被濫用時難以追責。
 - 若帳號建立與管理交接不完善，當帳號被濫用時，責任難以追蹤。
3. 流程漏洞 → 人員異動與帳號管理不嚴謹，易遭利用。
 - 顯示人員異動管理與帳號管理流程存在缺陷，可能成為不法人士利用的管道。

🔧 改善建議

1. HR 與 IT 流程整合
 - 要求 HR 或主管於帳號建立前確認合法需求，確保流程落實。
2. 留存稽核操作日誌並審查
 - 開啟系統稽核操作日誌以記錄使用者的操作行為，並定期對操作日誌進行分析，以識別是否有異常操作或權限濫用的跡象。
3. 強制首次登入改密碼
 - 人員到職前，其帳號之密碼由資訊權責人員保管，並於人員到職後，強制其變更密碼。

[返回摘要](#)



總覽

權限授予不適當

帳號啟用早於到職日

帳號許久未登入

離職帳號未停用

總結

1

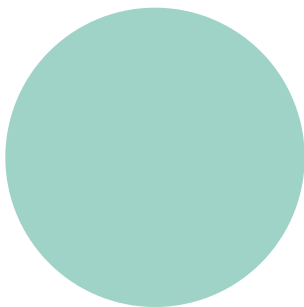
風險帳號計數

2%

風險帳號比率

風險帳號分類

● R&D



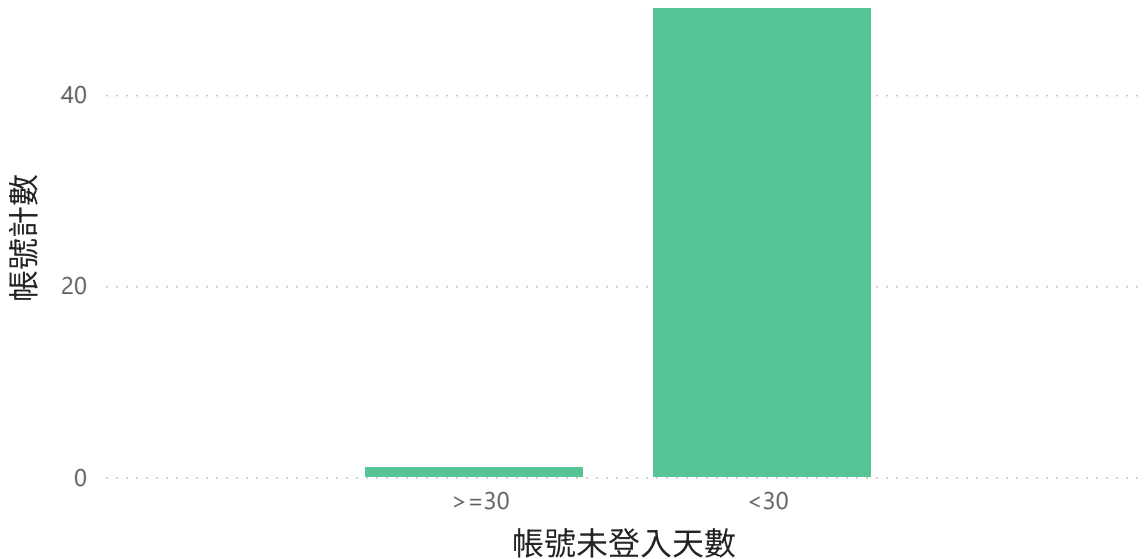
1 (100%)

風險帳號及對應權限

帳號	部門	人員狀態	職稱	帳號是否啟用	最後登入日期
ERP0012	R&D	在職	研發主管	True	2025/1/15

上次登入日與查核日相差天數

※查核日為2025/08/09



⚠ 風險摘要

- 安全威脅 → 可能遭盜用。
- 管理成本增加 → 增加帳號盤點、審核與清理作業負擔。

🔧 改善建議

- 定期審核及清理所有帳號

詳細說明



總覽

權限授予不適當

帳號啟用早於到職日

帳號許久未登入

離職帳號未停用

總結

風險帳號及對應權限

帳號	部門	人員狀態	職稱	帳號是否啟用	最後登入日期	權限	風險分類
ERP0012	R&D	在職	研發主管	True	2025/1/15	研發文件審核	帳號超過3個月未登入

⚠ 風險說明

- 安全威脅 → 可能遭盜用。
 - 離職員工帳號若持續存在，可能被內部或外部不法人士使用，導致敏感資訊外洩或系統受損。
- 管理成本增加 → 增加帳號盤點、審核與清理作業負擔。
 - 系統需持續維護無使用帳號，增加帳號盤點與審核負擔，部分帳號還需向系統廠商額外購買，造成資源浪費。

🔧 改善建議

- 定期審核及清理所有帳號
 - 定期檢視帳號是否仍需存在，依需求決定啟用、停用或刪除。
 - 設定期限（如 30天、90 天或 180 天），檢查長期未登入帳號，依公司規範停用或刪除。

返回摘要



總覽

權限授予不適當

帳號啟用早於到職日

帳號許久未登入

離職帳號未停用

總結

1

風險帳號計數

2%

離職後帳號未停用

離職人員帳號未停用

1 !

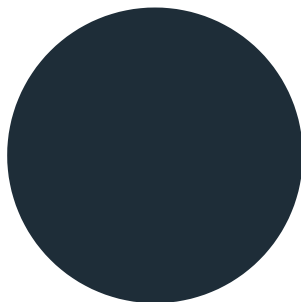
目標: 0

風險帳號及對應權限

帳號	部門	職稱	人員狀態	帳號是否啟用	離職日	
ERP0008	ITS	資訊人員	離職	True	2025/8/2	SUI

風險帳號分類

● ITS



1 (100%)

⚠ 風險摘要

- 1. 安全威脅 → 可能遭盜用。
- 2. 流程漏洞 → 顯示人員異動與帳號管理流程缺陷，易被利用。

🔧 改善建議

- 1. HR 系統串接/HR 與 IT 流程整合、自動鎖定帳號
- 2. 即時停用/刪除帳號
- 3. 帳號權限定期審查
- 4. 強化帳號監控與告警

詳細說明

[總覽](#)[權限授予不適當](#)[帳號啟用早於到職日](#)[帳號許久未登入](#)[離職帳號未停用](#)[總結](#)

風險帳號及對應權限

姓名	帳號	部門	職稱	人員狀態	帳號是否啟用	離職日	最後登入日	權限	風險分類
user0008	ERP0008	ITS	資訊人員	離職	True	2025/8/2	2025/8/2	SUPER_USER	離職後帳號未停用

⚠ 風險說明

- 安全威脅 → 可能遭盜用。
 - 離職員工帳號若持續存在，可能被內部或外部不法人士使用，導致敏感資訊外洩或系統受損，若該帳號為超級用戶將更為嚴重。
- 流程漏洞 → 顯示人員異動與帳號管理流程缺陷，易被利用。
 - 顯示人員異動管理與帳號管理流程存在缺陷，可能成為不法人士利用的管道。

🔧 改善建議

- HR 系統串接/HR 與 IT 流程整合
 - 離職流程自動觸發帳號停用，避免人工疏漏。
- 即時停用/刪除帳號
 - 於接收到HR通知後，停用離職人員之帳號，包含登入憑證、VPN、遠端存取。離職同時停用帳號。
- 帳號權限定期審查
 - 定期審查用戶權限是否仍必要，避免權限遺留。
- 強化帳號監控與告警
 - 針對超級用戶，強化日誌記錄與異常告警。

[返回摘要](#)



總覽

權限授予不適當

帳號啟用早於到職日

帳號許久未登入

離職帳號未停用

總結

權限授予不適當

改善方向：

- 權限最小化原則
- 留存操作日誌並定期審查
- 帳號權限定期審查

改善方向：

- HR 與 IT 流程整合
- 留存操作日誌並定期審查
- 強制首次登入改密碼

帳號久未登入

改善方向：

- 帳號權限定期審查

改善方向：

- HR 系統串接/HR 與 IT 流程整合、自動鎖定帳號
- 即時停用/刪除帳號
- 帳號權限定期審查
- 強化帳號監控與告警

帳號啟用早於到職日

離職帳號未停用

🔥 高風險項目

- **離職帳號未停用**：潛藏帳號濫用風險，建議即時停用帳號並強化監控機制。
- **權限授予不適當**：風險來自過度授權，應實施最小權限原則與定期稽核。

⚠️ 中風險項目

- **帳號啟用早於到職日、帳號久未登入**：可能造成無人管理帳號的資安漏洞，建議強化 HR 與 IT 流程整合，並實施自動鎖定機制。

🔧 建議整體提升措施

- 建立 HR / IT 流程自動化
- 導入帳號存取監控
- 定期權限審查制度
- 設計初次登入強制改密碼機制